

Security+ 4.6 · Access Controls

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 4.6 — Access Controls (7:49)** · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Access control models define how permissions are granted: ACL (per-resource list); MAC (mandatory based on CLASSIFICATION — military, SELinux); DAC (discretionary — the file OWNER decides, Windows FS); RBAC (role-based); ABAC (attribute-based); time-of-day restriction.

High-Yield Core Concepts Tested on Exam

- MAC: system decides based on classification (military/SELinux)
- DAC: the OWNER decides (Windows file permissions)
- RBAC: based on role (enterprise standard); ABAC: based on dynamic attributes
- ACL: list of permissions attached to a resource
- Time-of-day restriction: access limited to specific hours

Exam Tips & Classic Scenarios

- 'permissions determined by data classification' = MAC
- 'owner decides permissions' = DAC
- 'role-based access' = RBAC
- 'attribute-based access' = ABAC

Typical Exam Scenario: 'file only accessible by users with high clearance' = MAC.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 4.6 — Access Controls)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **RBAC:** Role-Based Access Control: Access model granting permissions based on organizational job roles rather than individual user identities.
- **ABAC:** Attribute-Based Access Control: Dynamic access control model evaluating user, resource, action, and contextual environment attributes (time, device posture, location).
- **MAC:** Mandatory Access Control: Rigid label-based access architecture (Top Secret, Secret, Unclassified) enforced centrally by security kernel according to formal classification policies.
- **DAC:** Discretionary Access Control: Access model where data owners possess complete discretion to assign read, write, or execute rights to other users.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. Giving each user ONLY the minimum access they need for their role is:

- A)** Least privilege
- B)** Separation of duties
- C)** Job rotation
- D)** Geographic need-to-know

2. The NIST CSF framework organizes security into 5 functions. What are they?

- A)** Install, Update, Test, Audit, Archive
- B)** Identify, Protect, Detect, Respond, Recover
- C)** Plan, Do, Check, Act, Review
- D)** Prevent, Punish, Predict, Prove, Publish

3. Corporate scenario (Access Controls): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.6), an analyst evaluates the following technical requirement: 'MAC: the system decides by classification (military/SELinux).' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: MAC: the system decides by classification (military/SELinux)...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

4. Corporate scenario (Access Controls): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.6), an analyst evaluates the following technical requirement: 'DAC: the OWNER decides (Windows file permission).' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: DAC: the OWNER decides (Windows file permission)...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

5. Corporate scenario (Access Controls): During a security review and compliance audit aligned with the CompTIA Security+ (SY0-701, Section 4.6) exam, an analyst evaluates the following technical requirement: 'RBAC: by role (the enterprise standard); ABAC: by dynamic attribute'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: RBAC: by role (the enterprise standard); ABAC: by dynamic attribute...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

6. Corporate scenario (Access Controls): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.6), an analyst evaluates the following technical requirement: 'permissions determined by data classification'=MAC'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to speed up system throughput
- B)** Implement the corresponding solution: 'permissions determined by data classification'=MAC...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

7. Corporate scenario (Access Controls): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.6), an analyst evaluates the following technical requirement: 'file only accessed by users with high clearance' = MAC. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: 'file only accessed by users with high clearance' = MAC
- D)** Allow shared access among administrators with generic credentials

8. Corporate scenario (Access Controls): During a security review and compliance audit aligned with the CompTIA Security+ (SY0-701, Section 4.6) exam, an analyst evaluates the following technical requirement: 'MAC: the system decides by classification (military/SELinux)'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: MAC: the system decides by classification (military/SELinux)...
- D)** Allow shared access among administrators using generic credentials

9. Corporate scenario (Access Controls): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.6), an analyst evaluates the following technical requirement: 'DAC: the OWNER decides (Windows file permission)'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: DAC: the OWNER decides (Windows file permission)...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

10. Corporate scenario (Access Controls): During a security review and compliance audit aligned with the CompTIA Security+ (SY0-701, Section 4.6) exam, an analyst evaluates the following technical requirement: 'RBAC: by role (the enterprise standard); ABAC: by dynamic attribute'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: RBAC: by role (the enterprise standard); ABAC: by dynamic attribute...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) A — Least privilege.

✓ **Why it is correct:** The correct answer is 'Least privilege'. The principle of least privilege determines that each user, process, or system should be granted only the permissions strictly necessary to perform its functions, and nothing more. In the information security context, this reduces the attack surface and limits the impact of a compromise. For example, a user in the finance department should not have access to human resources files. CompTIA Security+ SY0-701, in the Architecture and Design domain (2.1), lists least privilege as a fundamental security principle. The question describes exactly this definition: giving each user only the minimum access they need for their role.

✗ **Why the others are wrong:**

- *Separation of duties:* Separation of duties is a control that divides a critical task into steps performed by different people, so that no single person has total control over the process. For example, the person who approves a payment cannot be the same person who executes it. This prevents fraud and errors, but it does not refer to granting minimum access per user; instead, it distributes responsibilities. The question is about individual minimum access, not task division.
- *Job rotation:* Job rotation is the practice of periodically moving employees between different roles to detect fraud, reduce monotony, and train staff. It has no relation to the principle of granting only necessary access. Job rotation is an internal risk mitigation strategy, but it does not define each user's privilege level.
- *Geographic need-to-know:* Need-to-know is a security principle that restricts access to information only to those who need it to perform a specific task. However, 'geographic need-to-know' is not a standard term in the CompTIA Security+ certification. The concept of need-to-know is often associated with least privilege, but the expression 'geographic' adds a location restriction that is not present in the classic definition. The question does not mention geographic restriction, only functional minimum access. Therefore, the alternative is imprecise and does not correspond to the correct technical term.

2) B — Identify, Protect, Detect, Respond, Recover.

✓ **Why it's correct:** The NIST Cybersecurity Framework (CSF) 2.0 organizes cybersecurity activities into five core functions: Identify, Protect, Detect, Respond, and Recover. These functions represent the complete lifecycle of cyber risk management. 'Identify' involves understanding the organizational context, assets, risks, and vulnerabilities. 'Protect' covers implementing safeguards to ensure delivery of critical services. 'Detect' defines activities to identify the occurrence of cybersecurity events. 'Respond' comprises actions taken after an incident is detected. 'Recover' focuses on restoring capabilities or services that were impaired. This framework is widely adopted and required in the Security Architecture and Design domain of the CompTIA Security+ (SY0-701) certification, specifically in objective 2.1, which deals with frameworks and guidelines.

✗ **Why the others are wrong:**

- *Install, Update, Test, Audit, Archive:* These terms describe generic steps of an IT operational process, such as a software lifecycle or patch management, but they do not constitute the NIST CSF functions. 'Install' and 'Update' refer to system deployment and maintenance; 'Test' is a verification activity; 'Audit' is a compliance assessment; and 'Archive' is a data retention practice. None of these actions correspond to the high-level strategic functions defined by the NIST CSF, which are risk-oriented rather than tactical tasks.
- *Plan, Do, Check, Act, Review:* This is a variation of the PDCA cycle (Plan-Do-Check-Act), used in quality management and continuous improvement systems, such as ISO 9001. Although the NIST

CSF can be integrated into continuous improvement processes, its five functions are not 'Plan, Do, Check, Act, Review'. PDCA is a generic management model, while CSF functions are specific to cybersecurity and have their own scope and definitions. The inclusion of 'Review' as a fifth step is a distortion, as the classic PDCA has four steps.

- *Prevent, Punish, Predict, Prove, Publish*: These terms are not part of any recognized cybersecurity framework. 'Prevent' is a goal, but not a CSF function; 'Punish' is a disciplinary or legal action, not a security function; 'Predict' is an aspirational goal, not an operational function; 'Prove' and 'Publish' are audit and communication actions, respectively, but they do not compose the NIST CSF structure. This alternative mixes concepts of justice, prediction, and disclosure, with no relation to the official functions of the framework.

3) B — Implement the corresponding solution: MAC: the system decides by classification (military/SELinux)....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.6 (Access Controls): MAC: the system decides by classification (military/SELinux). Mandatory Access Control (MAC) is a strict access control model where the system enforces access based on security labels (classifications) assigned to subjects and objects, commonly used in military and high-security environments (e.g., SELinux).

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

4) B — Implement the corresponding solution: DAC: the OWNER decides (Windows file permission)....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.6 (Access Controls): DAC: the OWNER decides (Windows file permission). Discretionary Access Control (DAC) is a model where the owner of a resource determines who can access it and what privileges they have, as seen in Windows file permissions.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detect incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

5) B — Implement the corresponding solution: RBAC: by role (the enterprise standard); ABAC: by dynamic attribute....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for

lesson 4.6 (Access Controls): RBAC: by role (the enterprise standard); ABAC: by dynamic attribute.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

6) B — Implement the corresponding solution: 'permissions determined by data classification'=MAC....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.6 (Access Controls): 'permissions determined by data classification'=MAC.

✗ Why the others are wrong:

- *Temporarily disable audit logs to speed up system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

7) C — Implement the corresponding solution: 'file only accessed by users with high clearance' = MAC.

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.6 (Access Controls): 'file only accessed by users with high clearance' = MAC. Mandatory Access Control (MAC) enforces access based on security labels (clearance levels) assigned to subjects and objects, and users cannot override these restrictions.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

8) C — Implement the corresponding solution: MAC: the system decides by classification (military/SELinux)....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.6 (Access Controls): MAC: the system decides by classification (military/SELinux).

Mandatory Access Control (MAC) is a model where the system enforces access decisions based on security labels and classifications, commonly used in military environments and implemented in systems like SELinux.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

9) A — Implement the corresponding solution: DAC: the OWNER decides (Windows file permission)....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.6 (Access Controls): DAC: the OWNER decides (Windows file permission).

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

10) B — Implement the corresponding solution: RBAC: by role (the enterprise standard); ABAC: by dynamic attribute....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.6 (Access Controls): RBAC: by role (the enterprise standard); ABAC: by dynamic attribute.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

